

Организация

**ПОЛИТИКА ИНФОРМАЦИОННОЙ
БЕЗОПАСНОСТИ**

**Политика информационной
безопасности**

Объект защиты: Информационная система персональных данных

Категория: Персональные данные

СОГЛАСОВАНО:

Руководитель службы ИБ

«_____» _____ 20____ г.

г. Омск, 2026

Содержание

1	Общие положения	3
1.1	Область применения Политики	3
1.2	Нормативно-правовая база	3
1.3	Основные термины и определения	4
1.4	Технические меры защиты	4
1.5	Организационные меры и управление доступом	5
1.6	Шифрование и защита каналов связи	5
1.7	Журналирование и аудит	6
1.7.1	Обработка персональных данных и медицинская информация	6
1.7.2	Технические меры защиты информации	7
1.7.3	Управление доступом и шифрование данных	7
1.7.4	Инцидент-менеджмент и резервное копирование	8
1.8	Информационная безопасность (ИБ)	8
1.9	Персональные данные (ПДн)	9
1.10	Информационная система персональных данных (ИСПДн)	9
1.11	Уровень защищенности (УЗ)	10
1.12	Криптографические средства и шифрование	10
1.13	Журналирование событий и мониторинг	10
1.14	Управление доступом	11
1.15	Критические информационные ресурсы (КИР)	11
1.16	Технические меры	11
1.16.1	Управление доступом и идентификация	11
1.16.2	Шифрование данных	12
1.16.3	Сетевая безопасность и сегментация	12
1.17	Организационные и процедурные меры	13
1.17.1	Журналирование и мониторинг событий	13
1.17.2	Управление персоналом и документация	13
1.17.3	Резервное копирование и непрерывность деятельности	14

1.18	Принципы управления доступом	14
1.19	Идентификация и аутентификация	14
1.19.1	Многофакторная аутентификация	14
1.19.2	Управление учетными записями	15
1.20	Авторизация и права доступа	15
1.20.1	Ролевая модель доступа	15
1.20.2	Принцип минимальных привилегий	15
1.21	Технические меры защиты доступа	16
1.21.1	Шифрование данных	16
1.21.2	Журналирование событий	16
1.22	Управление доступом и инциденты	16
1.22.1	Процедуры пересмотра доступа	16
1.22.2	Реагирование на инциденты	17
1.23	Общие требования к обеспечению безопасности	17
1.24	Ответственность сотрудников	18
1.25	Техническое обеспечение и администрирование	18
1.26	Управление инцидентами и реагирование	19
1.27	Журналирование событий	19
1.28	Мониторинг и обнаружение угроз	20
1.29	Проведение аудита и проверок	20
1.30	Реагирование на инциденты	21
1.30.1	Область применения и действие Политики	22
1.30.2	Пересмотр и актуализация документа	22
1.30.3	Ответственность и исполнение	23
1.30.4	Взаимодействие с внешними контрагентами	23

Нормативные ссылки**24**

1. Общие положения

1.1. Область применения Политики

Политика определяет требования к обеспечению безопасности персональных данных и медицинской информации, обрабатываемых в БУЗОО «МИАЦ» (далее — Организация). Данный документ является обязательным для исполнения всеми сотрудниками, подрядчиками и иными лицами, осуществляющими деятельность на территории Организации, в частности, при работе с информационными системами, содержащими персональные данные пациентов и медицинские записи.

В соответствии с требованиями законодательства Российской Федерации, включая Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных» и Приказ Минздрава России от 28.02.2020 № 956н, должно быть обеспечено соблюдение конфиденциальности, целостности и доступности обрабатываемой информации. Политика регламентирует порядок действий при работе с информационными ресурсами, а также устанавливает ответственность за несоблюдение установленных процедур.

1.2. Нормативно-правовая база

Обеспечение информационной безопасности Организации базируется на совокупности нормативных актов. В частности, обязательным является соблюдение требований [152-ФЗ, ст. 19], регулирующих обработку персональных данных. Кроме того, в целях защиты медицинской информации, необходимо руководствоваться требованиями, изложенными в Приказе ФСТЭК России №21, который устанавливает требования к защите информации в государственных информационных системах.

Является обязательным также соблюдение требований, предъявляемых к медицинским организациям, согласно Приказу Минздрава России №956н. Таким

образом, все технические и организационные меры должны быть согласованы с указанными нормативными актами, обеспечивая комплексный подход к защите данных.

1.3. Основные термины и определения

В контексте настоящего документа используются следующие термины:

- **Персональные данные (ПДн):** Любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу.
- **Медицинская информация:** Данные, полученные в процессе оказания медицинской помощи, включая диагнозы, результаты обследований и назначения лечения.
- **Информационная система (ИС):** Совокупность программно-аппаратных средств, предназначенных для сбора, хранения, обработки и предоставления информации.
- **Уровень защищенности:** Классификация защищенности ИС, определяемая в соответствии с требованиями регуляторов и соответствующая критичности обрабатываемых данных.

1.4. Технические меры защиты

Необходимо внедрить комплекс технических мер, направленных на минимизацию рисков несанкционированного доступа. Обязуется обеспечить использование средств криптографической защиты информации (СКЗИ) при передаче ПДн и медицинской информации по незащищенным каналам связи.

Требуется организовать централизованное управление доступом к ИС. Доступ к критически важным данным должен предоставляться только по принципу минимально необходимых привилегий (Need-to-Know Basis). Запрещается использование личных или незащищенных носителей информации для хранения или передачи данных Организации.

Для обеспечения целостности данных и предотвращения несанкционированных изменений, требуется внедрить систему журналирования событий (SIEM). Производится постоянный мониторинг всех действий пользователей в ИС, что позволяет оперативно выявлять аномалии и попытки взлома.

1.5. Организационные меры и управление доступом

Организация обеспечивает разработку и актуализацию регламентов доступа к ИС. Каждый сотрудник, получающий доступ к ПДн, подлежит обязательному прохождению инструктажа по вопросам информационной безопасности.

Необходимо разработать и внедрить четкую процедуру реагирования на инциденты информационной безопасности. В случае обнаружения утечки или несанкционированного доступа, сотруднику предписывается немедленно уведомить ответственное подразделение.

С учетом требований [ФСТЭК №21, п. 15], должно быть обеспечено разделение обязанностей между сотрудниками, работающими с критически важными системами. Это означает, что полномочия по администрированию, разработке и эксплуатации ИС должны быть распределены между разными физическими лицами, предотвращая злоупотребление полномочиями.

1.6. Шифрование и защита каналов связи

Обязуется обеспечить шифрование всех каналов передачи ПДн и медицинской информации, передаваемых как внутри периметра Организации, так и за его пределы. Используются протоколы, такие как TLS 1.2 или выше, а также VPN-соединения с использованием надежных алгоритмов шифрования, например, AES-256.

При хранении ПДн на носителях информации, включая резервные копии, требуется применение криптографических методов защиты. Доступ к резервным копиям должен быть ограничен и осуществляться только после соответствующей

авторизации.

В соответствии с требованиями, при работе с данными, содержащими сведения о здоровье, должна быть реализована дополнительная защита, предусматривающая псевдонимизацию или полную анонимизацию данных перед их использованием в аналитических целях.

1.7. Журналирование и аудит

Осуществляется непрерывный сбор и анализ журналов событий (логирования) всех ИС. Журналирование должно фиксировать не только факт входа в систему, но и конкретные действия пользователя: просмотр, изменение, удаление записи.

Производится регулярная проверка журналов на предмет подозрительной активности, например, попыток доступа к данным в нерабочее время или попыток массового экспорта информации. Выполняется анализ этих данных с целью выявления потенциальных угроз и нарушения регламентов.

Политика определяет, что все журналы событий должны храниться в защищенном хранилище с установленным сроком хранения, что позволяет провести полноценный криминалистический анализ в случае инцидента. ## Нормативные ссылки

1.7.1. Обработка персональных данных и медицинская информация

В соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных», а также с учетом специфики обработки медицинской информации, регламентированной Приказом Минздрава России № 956н, должно быть обеспечено строгое разграничение доступа к сведениям о состоянии здоровья субъектов. Является обязательным внедрение механизмов, предотвращающих несанкционированный доступ к первичной медицинской документации. Политика определяет, что все действия с персональными данными должны осу-

ществляться исключительно на основании законного права субъекта или в рамках исполнения договора.

Необходимо внедрить комплекс мер по защите информации, обеспечивающих конфиденциальность и целостность обрабатываемых данных. В частности, требуется организовать системы учета и контроля доступа, которые фиксируют все попытки чтения, изменения или передачи информации. Обязуется обеспечить, что все сотрудники, имеющие доступ к ПДн, проходят регулярное обучение по вопросам соблюдения законодательства и корпоративной политики.

1.7.2. Технические меры защиты информации

В соответствии с требованиями ФСТЭК России (Приказ № 21), должно быть обеспечено применение сертифицированных средств защиты информации. Требуется организовать технические меры, направленные на минимизацию рисков утечки данных. Например, при передаче медицинских данных между филиалами или внешними контрагентами, обязательно использование защищенных каналов связи, таких как VPN или защищенные протоколы TLS.

Осуществляется мониторинг сетевого трафика с целью выявления аномальных запросов и подозрительной активности. Производится проверка настроек всех конечных устройств, подключенных к корпоративной сети, с целью исключения использования устаревшего программного обеспечения. С учетом требований ФСТЭК России, необходимо внедрить систему SIEM (Security Information and Event Management), которая агрегирует и анализирует журналы событий из различных источников.

1.7.3. Управление доступом и шифрование данных

Политика определяет, что доступ к критически важным информационным ресурсам предоставляется только по принципу минимально необходимых привилегий. Запрещается передавать персональные данные через незащищенные каналы связи, включая электронную почту без шифрования. Должно быть обеспечено

шифрование всех персональных данных, хранящихся в информационных базах, с использованием алгоритмов, соответствующих требованиям законодательства.

В соответствии с требованиями 152-ФЗ, необходимо разработать и внедрить регламент управления учетными записями. Обязуется обеспечить своевременную блокировку учетных записей сотрудников, прекративших трудовые отношения с организацией. Выполняется анализ рисков, связанных с использованием общих учетных записей, и принимается решение об их поэтапном исключении из оборота.

1.7.4. Инцидент-менеджмент и резервное копирование

Производится регулярная проверка резервных копий критически важных систем. Является обязательным наличие плана реагирования на инциденты информационной безопасности, который должен быть актуализирован не реже одного раза в год. В случае обнаружения нарушения режима защиты информации, должно быть немедленно инициировано реагирование, согласно утвержденной процедуре.

С учетом требований законодательства, необходимо обеспечить возможность восстановления работоспособности информационных систем в минимальные сроки после сбоя. Осуществляется мониторинг состояния систем резервного копирования, гарантирующий целостность и доступность резервных копий. Таким образом, обеспечивается непрерывность оказания медицинских услуг в условиях технического сбоя. ### Термины и определения

1.8. Информационная безопасность (ИБ)

Информационная безопасность представляет собой состояние защищенности информационных ресурсов, обеспечивающее их непрерывность, целостность и конфиденциальность. Данное состояние должно быть достигнуто путем реализации комплекса организационных и технических мер, предусмотренных в со-

ответствии с требованиями законодательства Российской Федерации. Политика определяет, что ИБ является непрерывным процессом, требующим постоянного мониторинга и актуализации. Необходимо обеспечить защиту информации от несанкционированного доступа, включая как внешние, так и внутренние угрозы. В частности, должно быть обеспечено соблюдение принципа минимально необходимых привилегий для всех пользователей, что является обязательным требованием при разработке систем доступа.

1.9. Персональные данные (ПДн)

Персональные данные — это любая информация, прямо или косвенно относящаяся к определенному или определяемому физическому лицу. Обработка ПДн подлежит строгому регулированию, согласно [152-ФЗ, ст. 19]. Организация обеспечивает защиту ПДн путем их обезличивания или шифрования при передаче через незащищенные каналы связи. Является обязательным выполнение процедур оценки рисков при сборе, хранении и использовании ПДн. Требуется разработка и внедрение внутренней документации, регламентирующей порядок получения согласия субъекта ПДн и сроки его уничтожения.

1.10. Информационная система персональных данных (ИСПДн)

ИСПДн представляет собой совокупность информационных ресурсов, предназначенных для обработки ПДн. В соответствии с требованиями [152-ФЗ, ст. 19], при создании ИСПДн должно быть обеспечено соблюдение требований к защите информации, включая физическое и техническое разделение систем. Система включает в себя не только программное обеспечение, но и аппаратные средства, а также регламенты доступа. Обязуется обеспечить, чтобы все компоненты ИСПДн были защищены от физического доступа посторонних лиц, что должно быть подтверждено результатами регулярных аудитов.

1.11. Уровень защищенности (УЗ)

Уровень защищенности — это количественный показатель, определяющий степень защиты информации от угроз, исходя из ее критичности и характера обрабатываемых данных. При разработке ИСПДн подлежит выполнению анализ угроз, который позволяет определить необходимый УЗ. В соответствии с требованиями ФСТЭК России, должно быть определено соответствие УЗ требованиям нормативных документов, например, [ФСТЭК №21, п. 15]. Производится проверка соответствия технических средств и организационных мер установленному УЗ.

1.12. Криптографические средства и шифрование

Криптографические средства — это программно-аппаратные комплексы, предназначенные для обеспечения конфиденциальности и целостности передаваемых данных. Шифрование данных является ключевым техническим мерой, направленной на защиту ПДн при их передаче или хранении. Необходимо внедрить использование сертифицированных средств криптографической защиты информации (СКЗИ), например, с использованием алгоритмов AES или TLS. Запрещается передавать ПДн в незашифрованном виде через публичные сети.

1.13. Журналирование событий и мониторинг

Журналирование событий — это процесс фиксации всех действий пользователей и системных компонентов в специальном журнале. Осуществляется мониторинг журналов в режиме реального времени с использованием специализированных систем (SIEM). Выполняется анализ журналов для выявления аномальных действий, попыток несанкционированного доступа или подозрительной активности. Является обязательным формирование регламента реагирования на инциденты информационной безопасности, который должен быть протестирован не реже одного раза в год.

1.14. Управление доступом

Управление доступом — это комплекс мер, регламентирующих, кто, когда и к каким информационным ресурсам имеет право доступа. Политика определяет, что доступ должен предоставляться строго по принципу “наименьших привилегий”. Необходима обязательная идентификация и аутентификация пользователей при каждом входе в систему. Требуется организовать периодическую переаттестацию прав доступа сотрудников, особенно при изменении их должностных обязанностей.

1.15. Критические информационные ресурсы (КИР)

Критические информационные ресурсы — это информационные системы, отказ или нарушение работы которых может привести к критическим последствиям для деятельности организации. В соответствии с требованиями законодательства, должно быть проведено категорирование информационных ресурсов. Обязуется обеспечить максимальный уровень защиты для всех ресурсов, отнесенных к категории КИР, включая резервирование и непрерывность бизнес-процессов. # Требования к защите

1.16. Технические меры

1.16.1. Управление доступом и идентификация

Обязуется обеспечить строгий контроль доступа к информационным ресурсам, включая медицинскую информацию пациентов. Должно быть обеспечено разграничение прав доступа в соответствии с принципом минимально необходимых привилегий, что является критически важным требованием [152-ФЗ, ст. 19]. Необходимо внедрить систему аутентификации, которая предусматривает использование не менее двух факторов (например, пароль и физический токен) при входе в критически важные информационные системы.

Система включает механизм учета всех действий пользователей, что позволяет фиксировать попытки несанкционированного доступа. Требуется организовать обязательную периодическую проверку учетных записей и прав доступа сотрудников, особенно в отношении персональных данных. В частности, доступ к базам данных с ПДн должен быть ограничен только профильными специалистами, чья деятельность напрямую связана с обработкой указанных данных.

1.16.2. Шифрование данных

Является обязательным применение криптографических средств защиты при передаче персональных данных. Обязательно использование протоколов TLS 1.2 или выше для всех каналов связи, передающих ПДн между рабочими станциями и серверами. При хранении данных в информационных системах должно быть обеспечено шифрование как на уровне базы данных, так и на уровне физического носителя.

Необходимо внедрить политики управления ключами шифрования, предусматривающие регулярную ротацию ключей и строгое хранение ключей в специализированных аппаратных модулях (HSM). Запрещается передавать зашифрованные данные по незащищенным каналам связи. В соответствии с требованиями ФСТЭК России, должно быть обеспечено использование сертифицированных средств криптографической защиты информации.

1.16.3. Сетевая безопасность и сегментация

Требуется организовать сегментацию корпоративной сети, что позволяет изолировать критически важные информационные системы от общедоступных и второстепенных рабочих зон. Обязуется обеспечить защиту периметра сети с помощью межсетевых экранов (Firewall) с функцией глубокой инспекции пакетов.

Необходимо внедрить систему обнаружения и предотвращения вторжений (IDS/IPS), которая осуществляет непрерывный мониторинг сетевого трафика на предмет аномальных или злонамеренных действий. Производится проверка кон-

фигурации сетевого оборудования на предмет соответствия установленным политикам безопасности.

1.17. Организационные и процедурные меры

1.17.1. Журналирование и мониторинг событий

Осуществляется мониторинг всех событий безопасности в режиме реального времени с использованием централизованной системы SIEM. Является обязательным ведение подробных журналов всех действий пользователей, включая время, тип операции и объект воздействия.

Политика определяет процедуру реагирования на инциденты информационной безопасности. При обнаружении признаков несанкционированного доступа или утечки данных, должно быть немедленно инициировано реагирование, включающее временное отключение затронутых систем и уведомление ответственных лиц.

1.17.2. Управление персоналом и документация

Обязуется обеспечить прохождение сотрудниками обязательного обучения по вопросам информационной безопасности и работе с ПДн. Должно быть разработано и утверждено Положение об обработке персональных данных, которое должно быть ознакомлено с подписями всех сотрудников.

Необходимо внедрить процедуру контроля физического доступа в помещения, где размещаются серверы и оборудование, предусматривающую обязательную регистрацию входа и выхода. С учетом требований Минздрава, должно быть обеспечено физическое разделение зон хранения медицинских карт и информационных систем.

1.17.3. Резервное копирование и непрерывность деятельности

Требуется организовать регулярное резервное копирование всех критически важных информационных систем и баз данных. Обеспечивается хранение резервных копий в географически удаленном месте для минимизации рисков потери данных.

Осуществляется периодическая проверка работоспособности процедур восстановления данных, что позволяет гарантировать непрерывность деятельности медицинской организации в случае сбоев или инцидентов. # Управление доступом

1.18. Принципы управления доступом

Политика определяет, что доступ к информационным ресурсам, содержащим персональные данные пациентов и сведения, составляющие врачебную тайну, должен осуществляться исключительно на основе принципа минимально необходимых привилегий. Должно быть обеспечено, что каждый пользователь получает доступ только к тем данным и функциям, которые строго необходимы для выполнения его должностных обязанностей. В соответствии с требованиями [152-ФЗ, ст. 19] и [ФСТЭК №21, п. 15], категорирование информационных систем и разработка матриц доступа являются обязательными этапами внедрения системы управления доступом.

1.19. Идентификация и аутентификация

1.19.1. Многофакторная аутентификация

Необходимо внедрить механизм многофакторной аутентификации (MFA) для всех учетных записей, имеющих доступ к критически важным информационным системам. Требуется использование как минимум двух независимых факторов: знание (пароль), владение (физический токен, смарт-карта) и/или присущие

пользователю характеристики (биометрия). Обязуется обеспечить, что учетные записи, принадлежащие сотрудникам, работающим удаленно, используют только защищенные каналы связи, например, VPN с обязательным шифрованием TLS.

1.19.2. Управление учетными записями

Организация обеспечивает централизованное управление жизненным циклом учетных записей. Подлежит выполнению процедура немедленной блокировки или аннулирования учетных записей в случае увольнения или изменения должностных обязанностей сотрудника. Производится регулярная проверка актуальности данных о сотрудниках и их должностных обязанностях, что является ключевым элементом предотвращения несанкционированного доступа.

1.20. Авторизация и права доступа

1.20.1. Ролевая модель доступа

Требуется организация и внедрение ролевой модели доступа (Role-Based Access Control, RBAC). Система должна быть настроена таким образом, что права доступа привязываются не к конкретному сотруднику, а к его должности или роли. Например, медицинский ассистент и заведующий отделением должны иметь разные наборы прав, несмотря на работу в одной и той же системе. Политика определяет, что права доступа должны быть задокументированы и утверждены руководителем подразделения.

1.20.2. Принцип минимальных привилегий

Обязуется обеспечить, что права доступа пользователя ограничиваются минимальным набором функций, необходимым для выполнения его прямых рабочих задач. Запрещается предоставление права администратора или суперпользователя сотрудникам, не относящимся к ИТ-персоналу, за исключением случаев, прямо предусмотренных должностной инструкцией и зафиксированных в акте

доступа.

1.21. Технические меры защиты доступа

1.21.1. Шифрование данных

Должно быть обеспечено шифрование персональных данных пациентов как при передаче, так и при хранении. При передаче данных между компонентами системы или внешними ресурсами обязательно использование протоколов с сильным шифрованием, таких как TLS 1.2 или выше. При хранении данных в базе данных подлежит применению шифрование на уровне полей, содержащих ПДн, с использованием алгоритмов, соответствующих требованиям [152-ФЗ, ст. 19].

1.21.2. Журналирование событий

Является обязательным ведение детализированного журнала всех действий пользователей в информационных системах. Осуществляется мониторинг всех попыток входа, успешных и неудачных запросов, а также операций по изменению, удалению или просмотру ПДн. Данные журналов должны храниться в системе SIEM (Security Information and Event Management) в течение установленного законом срока и подлежать регулярному анализу на предмет аномалий.

1.22. Управление доступом и инциденты

1.22.1. Процедуры пересмотра доступа

Необходимо внедрить процедуру периодического пересмотра прав доступа. В соответствии с требованиями [ФСТЭК №21, п. 15], владельцы информационных систем обязаны проводить аудит прав доступа не реже одного раза в квартал. Производится проверка соответствия фактических прав доступа должностным обязанностям сотрудника.

1.22.2. Реагирование на инциденты

В случае обнаружения подозрительной активности или несанкционированного доступа, должно быть обеспечено немедленное реагирование. Требуется организация механизма оперативной блокировки учетной записи и фиксация всех обстоятельств инцидента. Выполняется анализ причин нарушения доступа с целью предотвращения повторения подобных инцидентов в будущем. # Ответственность

1.23. Общие требования к обеспечению безопасности

Политика определяет, что обеспечение безопасности персональных данных и медицинской информации является непрерывным процессом, требующим участия всех структурных подразделений организации. Должно быть обеспечено строгое соблюдение требований законодательства Российской Федерации, в частности, Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных» и нормативных актов Министерства здравоохранения. Является обязательным проведение регулярных внутренних аудитов, направленных на выявление потенциальных уязвимостей и несоответствий установленным процедурам.

Необходимо внедрить систему контроля доступа, которая ограничивает обработку персональных данных только тем сотрудникам, которым эта информация необходима непосредственно для выполнения должностных обязанностей. Требуется организовать процесс управления инцидентами информационной безопасности, предусматривающий четкую последовательность действий при обнаружении несанкционированного доступа или утечки данных. В соответствии с требованиями ФСТЭК России, должно быть обеспечено документирование всех этапов жизненного цикла обрабатываемых данных, начиная от момента сбора и заканчивая их уничтожением.

1.24. Ответственность сотрудников

Каждый сотрудник организации обязуется проходить обязательный инструктаж по вопросам информационной безопасности и защите персональных данных. Запрещается передавать, копировать или хранить персональные данные пациентов и сотрудников на личных носителях информации, включая персональные электронные устройства. Обязательным является использование только утвержденных и защищенных каналов связи при обмене медицинской и персональной информацией.

Сотрудник обязан незамедлительно сообщать руководителю подразделения о любых подозрительных действиях, обнаружении физического доступа к защищенным зонам или выявлении признаков несанкционированного изменения системных настроек. Производится проверка соблюдения сотрудниками правил работы с учетными записями: запрещается использование общих логинов и паролей. В случае увольнения сотрудника, подлежит выполнению процедура немедленного изъятия всех корпоративных носителей и учетных средств доступа.

1.25. Техническое обеспечение и администрирование

Административно-технический персонал обязан обеспечить своевременное и полное обновление программного обеспечения всех рабочих станций и серверов, исключая использование устаревших версий, которые могут содержать известные уязвимости. Необходимо внедрить механизмы централизованного управления доступом, предусматривающие ролевую модель, которая минимизирует права доступа пользователей до минимально необходимых уровней.

Осуществляется мониторинг сетевого трафика и журналов событий с использованием специализированных систем SIEM, что позволяет оперативно выявлять аномалии и попытки взлома. Требуется организовать резервное копирование всех критически важных баз данных с соблюдением принципа «три копии», гарантирующим восстановление информации в случае сбоя или атаки. В соответ-

ствии с требованиями [ФСТЭК №21, п. 15], должно быть обеспечено физическое и логическое разделение систем, обрабатывающих разные категории данных.

1.26. Управление инцидентами и реагирование

Производится регулярная проверка готовности персонала к действиям в условиях инцидента информационной безопасности. Обязуется разработка и актуализация плана реагирования на инциденты, который должен быть доступен всем ключевым сотрудникам. В случае обнаружения утечки данных, необходимо немедленно инициировать процедуру локализации ущерба, включая отключение затронутых сегментов сети.

Подлежит выполнению анализ причин инцидента, с последующим составлением акта об обнаружении нарушения и определением мер по предотвращению его повторения. В рамках реагирования на инциденты, должно быть обеспечено ведение детализированного журнала всех действий, предпринятых по устранению последствий. Выполняется анализ соответствия произошедшего инцидента требованиям законодательства, что является критически важным для минимизации юридических рисков организации. # Контроль и аудит

1.27. Журналирование событий

Должно быть обеспечено непрерывное и полное журналирование всех действий, связанных с обработкой персональных данных и медицинской информацией. В частности, требуется фиксировать все попытки доступа к информационным системам, независимо от их результата. Необходимо внедрить механизмы регистрации всех операций изменения, удаления или просмотра записей в электронных медицинских картах.

Осуществляется мониторинг журналов событий в целях выявления несанкционированного доступа или подозрительной активности. Является обязательным сохранение журналов в течение установленного нормативными актами сро-

ка, что соответствует требованиям [152-ФЗ, ст. 19]. При этом должно быть обеспечено защитное хранение журналов, исключающее возможность их несанкционированного изменения или удаления.

Система журналирования должна обеспечивать временную синхронизацию всех записываемых событий, что критически важно для последующего анализа инцидентов. В соответствии с требованиями [ФСТЭК №21, п. 15], необходимо гарантировать целостность и неизменность данных, записанных в журналы.

1.28. Мониторинг и обнаружение угроз

Требуется организовать систему мониторинга безопасности, которая обеспечивает круглосуточное отслеживание сетевого трафика и активности пользователей. Необходимо внедрить средства обнаружения вторжений (IDS) и предотвращения вторжений (IPS), настроенные на выявление известных и потенциальных угроз.

Осуществляется мониторинг критически важных систем в режиме реального времени, что позволяет оперативно реагировать на отклонения от нормального режима работы. Политика определяет, что при обнаружении аномалий или попыток взлома должно быть инициировано автоматическое оповещение ответственных сотрудников.

С учетом требований [Минздрав №956н], должно быть обеспечено постоянное наблюдение за целостностью медицинских данных, передаваемых между различными информационными системами. Производится проверка сетевой инфраструктуры на предмет наличия уязвимостей, которые могут быть использованы злоумышленниками.

1.29. Проведение аудита и проверок

Является обязательным проведение регулярных внутренних аудитов информационной безопасности. Эти проверки должны охватывать все аспекты обработ-

ки ПДн, включая физическую защиту носителей информации и организационные процедуры. Необходимо разработать и утвердить регламент проведения аудитов, определяющий периодичность и состав аудиторской группы.

В соответствии с требованиями [152-ФЗ, ст. 19], должно быть обеспечено документирование результатов всех проведенных проверок. По результатам аудита составляется отчет, который обязательно включает перечень выявленных несоответствий и разработку плана их устранения.

Обязуется обеспечить участие внешних аккредитованных аудиторов в периодических проверках, направленных на подтверждение соответствия ИС требованиям регуляторов. Выполняется анализ соответствия применяемых технических средств и организационных мер действующим стандартам и нормативным документам.

1.30. Реагирование на инциденты

Необходимо разработать и утвердить План реагирования на инциденты информационной безопасности. Данный план должен четко определять последовательность действий при обнаружении любой угрозы, начиная от момента обнаружения и заканчивая восстановлением нормальной работы систем.

Осуществляется тренировка персонала по сценариям реагирования на инциденты, что является критически важным элементом поддержания высокого уровня готовности. В случае инцидента, должно быть обеспечено немедленное локализование угрозы, чтобы предотвратить дальнейшее распространение ущерба.

Политика определяет, что после устранения инцидента обязательно проводится детальный анализ причин его возникновения. Выполняется отчетность о произошедшем инциденте, которая направляется в соответствующие контролирующие органы в установленные сроки, согласно требованиям [ФСТЭК №21]. ##
Заключительные положения

1.30.1. Область применения и действие Политики

Политика определяет требования к обеспечению безопасности персональных данных и медицинской информации, обрабатываемых в БУЗОО «МИАЦ». Является обязательным документом для исполнения всеми сотрудниками, подрядчиками и третьими лицами, имеющими доступ к информационным ресурсам Организации. В соответствии с требованиями [152-ФЗ, ст. 19] и [ФСТЭК №21, п. 15], должно быть обеспечено соблюдение конфиденциальности, целостности и доступности обрабатываемой информации.

Система управления информационной безопасностью, на основе которой разработана данная Политика, включает в себя регламенты, инструкции и должностные обязанности, детализирующие порядок действий персонала. Организация обеспечивает регулярное обучение сотрудников, в частности, по вопросам обработки персональных данных и соблюдения режима конфиденциальности. Подлежит выполнению обязанность по неразглашению полученной служебной информации всеми лицами, ознакомленными с данными документами.

1.30.2. Пересмотр и актуализация документа

Политика подлежит обязательному пересмотру не реже одного раза в год, а также в случае существенного изменения нормативно-правовой базы или технологического ландшафта Организации. Требуется организовать процедуру анализа угроз безопасности информации, которая должна проводиться в соответствии с методическими рекомендациями, утвержденными в рамках системы защиты.

Производится проверка соответствия текущих технических и организационных мер требованиям законодательства. Обязуется обеспечить актуальность всех ссылок на нормативные акты, а также своевременное внесение изменений в структуру и содержание Политики. В случае обнаружения несоответствий, необходимо инициировать процесс корректировки документации, чтобы гарантировать непрерывность соблюдения требований.

1.30.3. Ответственность и исполнение

Ответственность за разработку, внедрение и поддержание актуальности Политики возлагается на ответственное должностное лицо, назначенное приказом руководителя. Необходимо внедрить систему контроля исполнения, которая позволяет фиксировать факт ознакомления каждого сотрудника с действующей редакцией документа.

Осуществляется мониторинг соблюдения регламентов информационной безопасности всеми структурными подразделениями. В случае выявления нарушений требований Политики, должно быть инициировано дисциплинарное разбирательство. Запрещается использование информационных ресурсов в целях, противоречащих целям деятельности Организации.

В соответствии с требованиями [ФСТЭК №21, п. 15], при возникновении инцидентов информационной безопасности, требуется немедленное информирование ответственных лиц и выполнение разработанного плана реагирования. Все действия по устранению инцидентов должны быть документированы, что является обязательным условием для проведения последующего анализа и аудита.

1.30.4. Взаимодействие с внешними контрагентами

Привлечение внешних поставщиков услуг или подрядчиков, работающих с персональными данными, требует обязательного заключения соглашений о неразглашении и передачи полномочий. Обязуется обеспечить, что все сторонние организации, обрабатывающие данные, соответствуют требованиям законодательства Российской Федерации в области защиты информации.

Производится проверка уровня защищенности информационных систем, используемых контрагентами, перед подписанием договоров. В случае передачи данных через внешние каналы связи, необходимо использовать только защищенные протоколы, такие как TLS или VPN, гарантирующие целостность и конфиденциальность передаваемой информации.

Нормативные ссылки

- Федеральный закон №152-ФЗ от 27.07.2006 «О персональных данных»
- Приказ ФСТЭК России №21 от 18.02.2013 «Об утверждении Составы и содержания организационных и технических мер по обеспечению безопасности персональных данных»
- Приказ Минздрава России №956н от 15.12.2020 «Требования к защите ПДн в сфере здравоохранения»